ONE-PAGE BRIEF

Post-quantum cryptography review: bitgo-mpc-en @ 3c892fd6a388

Client: BitGo — public repository (passive review) · Source: github.com/BitGo/BitGoJS, commit `3c892fd6a388` · Reviewed: 2026-11-04 18:37 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY

Level 0 of 4

no post-quantum cryptography

FINDINGS

0 Critical **0** High **9** Medium **0** Low **1** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 5 − 8 = 7 → **too late**

Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Medium QSI-2026-11792	**Quantum-vulnerable RSA: key wrapping and data encryption at rest (1 file(s))** confirmed by the analyst What to do: Wrap keys with ML-KEM or a hybrid KEM (X25519 + ML-KEM-768) and re-wrap the stored keys; data that may already have been copied needs its…
Medium QSI-2026-11786	**Quantum-vulnerable Ed25519: transaction and message signing (2 file(s))** confirmed by the analyst What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains…
Medium QSI-2026-11787	**Quantum-vulnerable ECDSA: transaction and message signing (10 file(s))** confirmed by the analyst What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains…
Medium QSI-2026-11788	**Quantum-vulnerable ECDSA: threshold signing and MPC protocols (10 file(s))** confirmed by the analyst What to do: Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the signature scheme; record which keys…

5 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium key wrapping and data encryption at rest	RSA	Wrap keys with ML-KEM or a hybrid KEM (X25519 + ML-KEM-768) and re-wrap the stored keys; data that may…
Medium threshold signing and MPC protocols	Threshold ECDSA, Paillier, ECDSA, RedDSA …	Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the…
Medium transaction and message signing	ECDSA, Ed25519	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum…
Medium role not determined	ECDSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)…

Analyst review: 9 confirmed, 0 not applicable, 0 dismissed as false positives. (QSI review, 2026-10-28)

Static review of source code and manifests; files analysed: 271. No requests were sent to the owner's systems.

Full report, content SHA-256: `38bce0925d7c971c44f19b16d5f05ed81e6d3158320e060b824044b1cb6ac506`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.